



University of Piraeus
School of Information and Telecommunications Technologies
Department of Digital Systems
Postgraduate Program "Government Security and Technological
Intelligence"

Security and Privacy Legal Framework

Spyware Technologies

Supervising Teachers: K. Lambrinoudakis - S. Grizalis

Vition Adriana	andriana_vition@ssl-unipi.gr
Kalaitzidis Ioannis	ioannis_kalaitzidis@ssl-unipi.gr
Spinoula Ioanna	ioanna_spinoula@ssl-unipi.gr

Piraeus

17/06/2026

Abstract

The rapid evolution of spyware from simple commercial surveillance tools (adware) to sophisticated state-sponsored spyware, such as Pegasus and Predator, has highlighted serious gaps in traditional cybersecurity strategies and existing legal privacy frameworks. This paper examines this multidimensional threat, analyzing infection mechanisms, such as zero-click attacks, and advanced anti-forensics techniques that make forensic detection extremely difficult. Through the retrospective technical study of the FORCEDENTRY attack (CVE-2021-30860) on iMessage, it is demonstrated how modern threats bypass isolation mechanisms (sandboxing) by exploiting memory management vulnerabilities.

In contrast to this technical failure, the paper proposes a methodology of ex-ante architectural design of information systems, focusing on a Health Information System (EHR). Guided by the ISO/IEC 29100 Privacy Framework and the ISO/IEC 27701 management standard, a zero trust model is developed. The protection of Personally Identifiable Information (PII) is achieved through strict Role-Based Access Control (RBAC)—based on the institutional example of Hong Kong's Cap. 625—purpose limitation, and the integration of Privacy Enhancing Technologies (PETs), such as pseudonymization. The research concludes on the need for a radical paradigm shift in software engineering, where privacy is not a simple regulatory compliance tool, but an organic and mathematically non-negotiable element of the architectural design of the code.

Contents

1. Introduction to Digital Espionage and Threat Evolution	4
---	---

1.1	Definition of spyware and distinguishing it from other malware	4
1.2	From adware to state-sponsored spyware	5
1.3	Goals, incentives and the "Digital Panopticon"	6
1.4	The Necessity of Paradigm Shifting in Software Engineering	7
2.	Infection mechanisms, architectural and digital forensic detection (forensics)	8
2.1	Social engineering, spear-phishing and zero-click attacks	9
2.2	Architectural and technical analysis of modern threats	9
2.2.1	The ecosystem of Pegasus (NSO Group).....	9
2.2.2	The Predator ecosystem (Cytrox/Intellexa)	10
2.3	Anti-forensics/memory-only techniques.....	11
2.4	Digital forensics and detection tools (logs, packet, capture, MVT)	12
2.5	Need to move from repressive defense to organic privacy planning	13
3.	ISO/IEC 29100 Framework and Privacy Requirements Engineering	14
3.1	Paradigm shift in software engineering	14
3.2	Conceptual foundation and definition of personal data (PII).....	15
3.3	Actors and roles in the software lifecycle	16
3.4	The privacy principles of ISO 29100 as a barrier to data leakage	17
3.5	Requirements Engineering and Architectural Design: The Integration of Privacy by Design	17
4.	The gap between the legal framework and technological reality.....	18
4.1	The limits of European Law (GDPR) against State-Sponsored Spyware....	18
4.1.1	Legal loopholes and grey areas in the availability of spyware	19
4.2	The need for technological (and not only legal) shielding of software	20
5.	Case Study 1-Vulnerability analysis and redesign of messaging platforms (iMessage/FORCEDENTRY).....	21
5.1	Scenario description and anatomy of the FORCEDENTRY attack	22
5.1.1	Background and evolution of NSO Group's zero-click attacks	22
5.1.2	The discovery and context of the FORCEDENTRY attack	22

5.1.3 Technical analysis and anatomy of CVE-2021-30860	23
5.2 Failure analysis of traditional security mechanisms	24
5.3 Structural security upgrades in iOS 15 and their correlation with ISO/IEC 29100 and PETs	25
6. Case Study 2-Electronic Health Record (EHR) Development	26
6.1 Design of a health information system against advanced threats (zero-click spyware).....	27
6.2 Modeling of roles, access rights (RBAC) and purpose limitation based on ISO 29100.....	28
6.3 Integration of privacy-enhancing technologies (PETs) and data de-identification	29
7. Conclusions	30
7.1 Challenges in the Practical Application of Privacy Standards vs. Commercial Spyware.....	30
7.2 Recap and Future Directions in Software Engineering.....	30
8. Bibliography	32
9. Performance tables of terms.....	Error! Bookmark not defined.
9.1 Table of terms (English to Greek)	Error! Bookmark not defined.
9.2 Rendering Table (Greek to English)	Error! Bookmark not defined.

1. Introduction to Digital Espionage and Threat Evolution

1.1 Definition of spyware and distinguishing it from other malware

Spyware is a special category of malware, which is designed with the primary purpose of secretly collecting, monitoring and transmitting information from a device or information system, without the user's substantial knowledge, consent or active participation. Unlike other forms of malware, such as ransomware or destructive viruses, spyware does not necessarily aim to shut down or directly damage the system, but to make it as quiet and prolonged as possible within the target's digital environment. Its success depends on its invisibility, because the less it is perceived, the greater the range and duration of the information it can extract.

The specificity of spyware lies in the type, sensitivity, and depth of data it can access. Through its function, it is possible to intercept messages, contact lists, communication histories, location data, application data, images, files, and even user behavior patterns. This extent means that this is not a simple technical cybersecurity incident, but an infringement of multiple aspects of the individual's privacy, communication autonomy and personality. In the modern literature and in European institutional texts, spyware is treated for this very reason as a technology of deep interference at the core of fundamental rights [1].

Distinguishing spyware from related technologies, such as adware or keyloggers, is particularly important on both a technical and legal level. Adware is primarily associated with commercial tracking and targeted advertising practices, while keyloggers pertain to specialized keystroke logging tools. Spyware, on the contrary, constitutes a broader surveillance platform with the possibility of combined access to multiple levels of the user's system and digital environment. This qualitative difference explains why this study is not limited to cybersecurity, but is closely linked to personal data law, privacy of communications, and digital rights theory [2]. In addition, the technical literature categorizes modern, complex spyware (such as Pegasus and Predator) as "state-grade spyware" tools, which have the ability to bypass the encryption of messaging applications, exploiting zero-day flaws [3]. Unlike commercial or criminal spyware, this type of software is designed to gain full and invisible access to the device, extracting data and controlling sensors (camera, microphone) in real time [4].

1.2 From adware to state-sponsored spyware

The historical evolution of spyware highlights a clear and gradual transition from simple forms of unwanted commercial surveillance to highly sophisticated technologies with strong political, institutional and geostrategic importance. In the early stages of its development, monitoring software often emerged as a deceptive addition to other programs or as a tool for recording user behavior for commercial purposes. However, as the value of digital data and the centrality of electronic devices in everyday

life increased, so did the character of these technologies towards more invisible, more persistent and more invasive forms of surveillance.

This transition is directly linked to the transformation of the smartphone into a key hub of personal, professional and social activity. The modern mobile device is not just a means of communication, but a repository of photos, conversations, identity data, location information, financial transactions, contacts, business documents and interfaces with other digital services [2]. This means that the successful hacking of a mobile phone provides the attacker with not fragmentary information, but the ability to reconstruct an almost complete digital profile of the user. The device is thus transformed from an everyday communication tool into a point of total exposure of the subject's life [1].

In this technological and political environment, the so-called mercenary or state-sponsored spyware emerged, i.e. highly technologically specialized software developed by private companies and made available or used by state or other institutional bodies for targeted surveillance. A key milestone for this shift was the discovery of the Ghostnet network (2009), one of the first large-scale cyberespionage campaigns, which marked the definitive transition of spyware from a tool of financial crime to a superweapon of geopolitical influence [5]. The Pegasus and Predator cases have shown very clearly that cyber espionage is no longer an exclusive tool of state intelligence, but also the subject of internationalized commercial activity. This privatisation of surveillance exacerbates the issues of accountability, export control, cross-border liability and institutional transparency. Spyware is therefore not just a technical issue, but a phenomenon that directly affects the rule of law and the functioning of democracy [6].

1.3 Goals, incentives and the "Digital Panopticon"

The use of spyware is often justified by government authorities with reference to the need to prevent or suppress terrorism, organized crime, and other serious threats to national security. However, European institutional research and public disclosures show that these tools have also been used in cases that clearly go beyond this narrow

scope, targeting journalists, politicians, activists, lawyers, researchers and civil society representatives. This indicates that spyware can be transformed from a security tool into an instrument of surveillance of public life, with potential consequences for political competition, freedom of the press and democratic pluralism.

Spyware therefore functions not only as a technology for technical access to data, but also as a mechanism for generating knowledge and, through it, generating power. Through access to a person's digital footprint, the spyware operator can map the target's relationships, contacts, communication patterns, political or professional connections and the social network in general. In this way, spyware enables not only information gathering but also understanding the subject's position within broader structures of influence and interdependence. It is precisely this character that makes it an extremely powerful tool for control and intervention [6].

The theoretical understanding of the phenomenon can be linked to the concept of the digital Panopticon, i.e. a regime in which the very possibility of continuous surveillance produces a disciplinary effect. When the person knows or reasonably suspects that their personal device may act as a constant monitoring tool, they may limit their communication, review their contacts, avoid certain expressions, and self-censor. Thus, the damage caused by spyware is not limited to the violation of privacy, but extends to the alteration of behavior and the shrinking of the scope of free social and political action. On this basis, digital espionage affects not only the individual, but also the very state preconditions of democratic participation [2].

1.4 The Necessity of Paradigm Shifting in Software Engineering

The experience of using sophisticated spyware tools highlights the limits of traditional cybersecurity logic with particular intensity. The perception that protection is achieved mainly through back-up updates, defensive applications and remedies proves inadequate in the face of mechanisms that are complex, inconspicuous and in some cases do not even require user interaction [1]. When the attack takes place in the background and is extremely difficult to detect, privacy protection cannot remain an

afterthought, it must be a component of the system architecture from the first design stage [2].

ISO/IEC 29100:2024 provides a crucial theoretical and regulatory framework for this shift. The standard defines a privacy framework that introduces common privacy terminology, identifies key roles in the processing of personally identifiable information (PII), and describes privacy safeguarding considerations for information environments. At the same time, the text of the standard itself clarifies that it applies to individuals and organizations involved in the design, development, testing, maintenance, management and operation of ICT systems or services in which privacy controls are required. Therefore, privacy is not treated here as a regional compliance requirement, but as an organic element of information systems engineering and governance [7].

In light of this, the essential response to spyware cannot be limited to suppression or post-attack detection. Planning is required that incorporates data minimization, clear definition of roles and responsibilities, information lifecycle management, and the implementation of systematic privacy controls. Only such a model can reduce the scope of data exposed, limit opportunities for abusive access, and create real resilience against modern forms of digital espionage. In this sense, dealing with spyware is both a technical, institutional and architectural challenge [6].

2. Infection mechanisms, architectural and digital forensic detection (forensics)

2.1 Social engineering, spear-phishing and zero-click attacks

The mechanisms of spyware infection operate across a wide spectrum, from relatively simple techniques to deceive the user to highly advanced attacks carried out without any active involvement of the victim. Social engineering relies on the psychological manipulation of the user, utilizing trust, curiosity, a sense of urgency or the invocation of authority. In this context, the victim is enticed to open a link, download a file, or interact with content that seems safe or familiar. Spear-phishing is a more targeted version of this practice, as the message is specifically tailored to the professional, social or personal profile of the target, significantly increasing the effectiveness of the attack [8].

At an even more sophisticated level are zero-click attacks, which are among the most alarming forms of digital infiltration. In these cases, the infection can take place without clicking, without opening a link, without installing a file, and without any conscious action by the user. The success of the attack depends on vulnerabilities in how platforms, operating systems, and applications process incoming content, such as messages or files. This means that the source of the risk is shifting from incorrect human behavior to the very architecture of information systems. This is a development that reinforces the need to integrate privacy and security into software design [1]. On a technical level, zero-click attacks are highly complex exploit chains, which target mobile operating systems by bypassing established security measures, such as sandboxing or code signing [9]. Due to their nature, these types of attacks are carried out quietly and leave little to no forensic evidence on the victim's device [10].

2.2 Architectural and technical analysis of modern threats

2.2.1 The ecosystem of Pegasus (NSO Group)

Pegasus is the most well-known and iconic example of advanced commercial spyware, as it is associated with sophisticated attacking capabilities that allow the hacking of mobile devices and the extraction of the data stored or processed on them. Its importance is not limited to the technical integrity of the attack, but lies mainly in

the fact that it makes the mobile phone itself a multi-level surveillance mechanism. Upon successful infection, the device ceases to function only as a means of communication and turns into an access point to the user's private, professional and social life.

The case of Pegasus is also of particular importance at institutional level, because it shows that digital surveillance of this type is not just about collecting individual messages or data. Access to communications, applications, metadata, location, files and other device elements poses serious risks to privacy, data protection, freedom of expression, freedom of the press and ultimately the democratic process. For this reason, the European Parliament's studies treat Pegasus as a technology that affects not only individual rights, but also the basic values on which the democratic order is organized [8]. The commercialization and the business model of making this platform available follow the standards of conventional industrial software. As can be seen from the official product description manual, "one year of maintenance, support and upgrades services" is provided by default. Technical support is organized into three tiers (three-tier level support): "Tier-1: Typical system operation problems", "Tier-2: Proactive resolution of technical problems" with the provision of "remote assistance using remote desktop software and Virtual Private Network (VPN)", and "Tier-3: Bug fixing and system updates for essential malfunctions". At the same time, the development framework includes the issuance of "major upgrades to the Pegasus system several times a year", with the aim of incorporating "new features" and "supporting new devices and operating systems" [12].

2.2.2 The Predator ecosystem (Cytrox/Intellexa)

Predator is another extremely important case of mercenary spyware, because it highlighted that the international cyber espionage ecosystem is not limited to just one company or technology platform. According to Citizen Lab's findings, two Egyptian targets were compromised with Predator, while in the case of Ayman Nour, simultaneous contamination with both Predator and Pegasus was found, which were attributed to different government clients. This is particularly critical because it reveals that different espionage tools can operate in parallel in the same political and

technological environment, increasing the complexity of surveillance and investigation [13].

The significance of the Predator case is not only technical but also economic-political. The existence of corporate schemes that develop, market and support such technologies reveals that digital surveillance has already formed a particular market field, in which technological power is directly linked to issues of accountability, supervision and export control. The study of Predator thus contributes to the understanding not only of how spyware works, but also of the political economy that makes its spread possible. In this sense, Predator is not just a hacking tool, but also an indicator of how surveillance technology is integrated into international power networks [13].

2.3 Anti-forensics/memory-only techniques

The effectiveness of modern spyware does not depend solely on the initial success of the breach, but also on its ability to remain functional or extract data without being easily detected. For this reason, these tools are associated with techniques of concealment, limitation of traces, minimization of the obviously malicious footprint and general difficulty of technical analysis. This concealment has practical value because it reduces the likelihood of early detection and allows for a longer duration or effectiveness of surveillance. At the same time, it makes it clear that spyware is not only designed to enter a system, but also to maintain a condition of invisible presence [8].

The difficulty of detection is also of particular importance at the evidentiary level. The absence of a stable, readily recoverable or easily visible evidence does not necessarily mean that the breach did not occur, but may be precisely an indication of the technological maturity of the attack. This necessitates a more complex logic of assessing indications, in which the absence of obvious artifacts is not automatically interpreted as the absence of a threat. In spyware cases, technical investigation and legal judgment must therefore take into account the possibility of anti-forensics features and detection avoidance mechanisms [8]. This difficulty is exacerbated by built-in self-destruct mechanisms and obfuscation. For example, if the software detects the presence

of digital forensic analysis tools or detects a critical change in the environment (such as changing the SIM card), it can delete itself, corrupt the relevant logs or even replace parts of the memory with null bytes [14].

2.4 Digital forensics and detection tools (logs, packet, capture, MVT)

Digital forensic analysis in mobile device spyware cases is one of the most demanding fields of modern cybersecurity. The relevant items are often fragmentary, time-unstable, technically complex and dispersed across different layers of software, applications and network communications. For this reason, the investigation is based on a combination of methods, such as the study of log files, the analysis of backups, the search for network indicators and the temporal correlation of individual events. The value of this methodology lies not only in the detection of a "malicious file", but in the synthesis of technical indications that make the existence of a violation possible or provable. As traditional antivirus software usually fails to detect these threats, digital forensics relies crucially on specialized tools, such as the Mobile Verification Toolkit (MVT), which automates the analysis of encrypted backups looking for suspicious traces (Indicators of Compromise) [16]. In addition, the analysis of network traffic (packet capture) combined with the detection of anomalies in the behavior of applications – such as unexpected battery consumption or undue camera activation – play a crucial role in uncovering infection [16].

The importance of digital forensic analysis is not only technical but also institutional. Its findings can form the basis for public accountability, independent institutional investigation, judicial review, and assessment of potential violations of fundamental rights. In this way, digital forensics acts as a bridge between technological knowledge, proof and the institutional protection of democracy. Especially in environments where monitoring is inconspicuous and evidence is limited, its importance increases even more, as it is one of the few mechanisms that can restore transparency and accountability [17]. In addition, during the process of examining targeted individuals by specialized Digital Forensics Labs, the technical investigation is framed by specific documentation questions, such as: "When did you first notice that

something was wrong? What did you notice? What did you do at that point?" as well as "Had you taken any precautions online before this attack?" [18].

2.5 Need to move from repressive defense to organic privacy planning

The characteristics of modern spyware threats demonstrate that the defense strategy cannot be based solely on retrospective detection or remediation. When attacks are invisible, deeply invasive, and sometimes zero-click, protection cannot depend solely on detection tools or delayed corrective interventions. A model is needed in which privacy and security are treated as organic elements of the system itself, already from the architectural conception phase [19].

ISO/IEC 29100:2024 supports exactly this logic, as it describes a privacy framework applicable to organizations and individuals who design, develop, maintain or operate ICT systems or services where privacy controls are required for PII processing. The defense against spyware must thus be based on privacy safeguarding requirements, privacy policies, a clear division of roles and systematic privacy controls [20].

3. ISO/IEC 29100 Framework and Privacy Requirements Engineering

3.1 Paradigm shift in software engineering

The traditional approach to information security has always focused on the perimeter protection of systems, which is based on the installation of firewalls, intrusion detection systems and antivirus programs at the network borders in order to create a "fortress" around the infrastructure. This model assumes that the threat lies exclusively outside the network, but the advent of sophisticated attacks, such as zero-click spyware (e.g., Pegasus), has proven that attackers can penetrate directly inside the network by exploiting unknown vulnerabilities, making perimeter defenses obsolete. For this reason, software engineering requires a paradigm shift and is moving towards the international standard ISO/IEC 29100 [7]. The transition to ISO 29100 is not a simple addition of new security tools, but a fundamental overhaul of how organizations perceive and protect their information systems, putting information control and governance at the heart of the software development lifecycle [21].

In the traditional security model, the main concern was the protection of "Information Assets", a term that includes servers, databases, networks and any information that has value to the organization, with the main objective of ensuring business continuity [22]. On the contrary, privacy engineering radically changes this thinking. The centre of gravity is shifting from the organisation's assets to 'Personally Identifiable Information' (PII), i.e. data relating to and capable of identifying the natural person himself (PII Principal) [23]. The whole rationale of privacy engineering is based on the assumption that a security breach is now an inevitable reality, so protection must be built (by design) into the software architecture itself and how PII is managed, so that the information remains secure even if the infrastructure crashes or becomes infected.

In this new model, classic security controls evolve into specialised "Privacy Controls", which are technical, administrative or organisational measures (such as

pseudonymisation, point-to-point encryption and strict access restriction) applied directly to the data flow to mitigate risks [24]. This model essentially defines the architectural form that a system should adopt. A zero trust structure, which manages data in such a way that, even if a terminal device is infected by a privacy risk or breach, the damage is isolated and sensitive data is not exposed [25]. For the software mechanism, its relationship with the new model is direct, as it is deeply affected by the redefinition of its goals. The original objectives of traditional security, which were simply to maintain the Control Objectives to shield the infrastructure, are now replaced or supplemented by the "Privacy safeguarding requirements" [26]. In order for the system to be even more secure today compared to the past, the end goals of the software must be transformed from passive (post-attack reaction) to active and organic (proactive planning), ensuring that privacy risk management is performed continuously at every stage of the code, neutralizing the ability of spyware to steal useful information [27].

3.2 Conceptual foundation and definition of personal data (PII)

The foundation of privacy protection in software technology requires the precise identification of the object of protection, which in the context of ISO/IEC 29100 is defined as Personally Identifiable Information (PII) [28]. According to the Official International Standard, PII means any information that can either be used to identify the natural person to whom it refers, or is or may be directly or indirectly linked to it [29]. The natural person to whom this information refers is strictly defined as the PII principal [30]. In the architectural design of information systems, this subject is the central reference entity, whose rights and confidentiality must be organically ensured through the structure of the code [23].

For the software engineer, understanding the scope of this definition is crucial, as implicit identification includes data that is often mistaken for mere technical metadata. In order to determine whether a PII subject is identifiable, all means that are reasonable to be used by the controller or any other person to identify him or her must be taken into account [31]. Elements such as IP addresses, unique device fingerprints, GPS logs, and network traffic metadata fully fall under the category of PII, as they can be combined to lead to the indirect disclosure of the user's identity.

This conceptual broadening becomes crucial when dealing with sophisticated spyware, as the digitalisation of processes and the expansion of information and communication technologies are constantly creating new risks for PII protection [32]. Modern state spyware is not limited to intercepting obvious files, but functions as mechanisms for mass collection of behavioral data, constantly extracting telemetry and sensor data. For this reason, traditional security objectives need to be revised, as security controls can be economic, organisational, legal, technical, procedural or conceptual, providing a high-level framework for the shielding of PII within information systems [21].

3.3 Actors and roles in the software lifecycle

When designing and deploying privacy-oriented information systems, it is necessary to identify in advance all entities with a legitimate interest, which are defined as privacy stakeholders [33]. At the core of these stakeholders is the PII principal, i.e. the natural person to whom the personally identifiable information refers [30]. The central responsibility for decision-making on the management of information lies with the PII controller, who determines the intended purposes and means of the processing of personal data [34].

On the other hand, the technical implementation of this processing is often entrusted to the PII processor, who processes the information strictly on behalf of and in accordance with the instructions of the controller [35]. In addition, the architecture of the software must anticipate and control the flow of information to any third party, which represents any privacy stakeholder other than the subject, the controller and the processor [36].

The strict isolation of these roles in code and access rights (access control) is fundamental to the shielding of the system. If sophisticated spyware infects an end-user's device, the absence of distinct roles and restrictions would allow the malware to steal global permissions and gain unauthorized access to the entire data processing ecosystem, disrupting the flow between controllers and processors.

3.4 The privacy principles of ISO 29100 as a barrier to data leakage

The practical shielding of an information system against data leakage caused by sophisticated spyware is based on the integration of the eleven (11) privacy principles established by the ISO/IEC 29100 model [37]. These principles are not mere theoretical directions, but are translated into specific architectural countermeasures, starting with the principles of consent and choice and purpose legitimacy and specification, which ensure that the processing flow is strictly and exclusively limited to the objective objectives approved in advance by the subject [38].

A key role in the technical interception of spyware is played by the principles of collection limitation and data minimization, which require the software engineer to limit the collection and processing of PII to the minimum necessary, drastically reducing the attack surface and the amount of information that could be intercepted in the event of device infection [39]. At the same time, the use, retention and disclosure limitation ensures that data are automatically deleted as soon as their purpose is fulfilled and are not exposed to third parties, while the principles of accuracy and quality and openness, transparency and notice guarantee the integrity of the data and the full visibility of the processing processes [40].

Protection is integrated at the code level through the principles of individual participation and access and accountability, which are inextricably linked to the principle of information security for the enforcement of cryptographic controls, and the principle of privacy compliance which verifies the overall resilience of the system [41].

3.5 Requirements Engineering and Architectural Design: The Integration of Privacy by Design

Effective protection of an information system from advanced threats, such as spyware, is not achieved by the suppressive addition of security measures after the development is complete. Instead, it requires the adoption of the "Privacy by Design" (PbD) architectural approach, which requires the integration of privacy requirements at every stage of the Software Development Life Cycle (SDLC). As underlined in the

ISO/IEC 29100 framework, this process translates theoretical principles into tangible "Privacy safeguarding requirements", which must be treated by engineers as primary control objectives of architecture [26].

In the context of requirements engineering, this methodology requires the design of the system with the assumption of Zero Trust. Privacy controls are not just treated as legal obligations, but as strict technical, organisational and procedural constraints imposed on the information and communication technology (ICT) infrastructure itself [21]. In practice, this means that during the architectural design phase, engineers must model data streams in such a way that access to personally identifiable information (PII) is limited from the outset (Privacy by Default) [42].

Incorporating privacy into the design acts as an organic barrier against spyware. Even in the case of a successful breach of the security perimeter, a well-designed architecture – which has implemented privacy risk management from the early stages of analysis [27] – guarantees that the data is either encrypted, fragmented, or inaccessible due to strict roles, making the intercepted PII virtually useless to the attacker. In this way, the ISO 29100 framework acts as the foundation upon which durable applications are built, consistently protecting the rights of the subject [43].

4. The gap between the legal framework and technological reality

4.1 The limits of European Law (GDPR) against State-Sponsored Spyware

The rapid evolution and availability of sophisticated commercial spyware technologies have highlighted an obvious imbalance between existing regulatory

mechanisms and the digital reality. At the heart of European privacy legislation is the General Data Protection Regulation (GDPR), which was designed to set a strict personal data governance (PII) framework. Although this regulation explicitly recognises that spyware surveillance practices fundamentally violate the right to privacy, its practical implementation encounters insurmountable structural and jurisdictional limits when it comes to dealing with attacks orchestrated by state-sponsored actors through tools such as Pegasus or Predator [44].

As documented in the academic literature, software such as Pegasus violates both national and international data protection laws, as they operate without the informed consent of the users [44]. These tools gain full access to personal data without the slightest prior notification or approval of the subjects, effectively depriving them of the right to an informed decision regarding the management of their private sphere.

The GDPR mainly regulates the activities of commercial entities and bodies, but explicitly excludes from its scope activities related to national security and public order, which fall under the exclusive competence of the Member States. State intelligence agencies exploit this institutional gray area, invoking national security secrecy to legitimize the use of mass or targeted surveillance tools. Consequently, data protection supervisory authorities are deprived of the jurisdiction to control or sanction state structures that use spyware, rendering the rights of subjects, such as the right to be informed or erased, practically inactive.

In addition, the mechanisms of the GDPR are based on the principle of transparency and accountability of controllers, assuming that the user knows or can find out who is processing their data. The architecture of state-sponsored spyware, on the other hand, is based on the opposite. Zero-click attacks run in the background without any indication, while Command and Control infrastructures use multiple layers of proxies and virtual companies to hide the identity of the end user. This asymmetry of information makes it impossible to establish legal liability, as the victim is unable to prove which government entity or which intermediary breached his device.

4.1.1 Legal loopholes and grey areas in the availability of spyware

The gap between legislation and technological reality is further widened by the generalised uncertainty at international level as to whether international legislation explicitly and effectively condemns spyware [45]. At this stage, there are no clear and universal limits on the legality of developing, marketing and using these tools, which allows cyber espionage to be carried out at the transnational level against various groups without substantial legal consequences.

Within this regime of international legislative vacuum, companies that develop this software, such as NSO Group and Intellexa, operate with great flexibility. Although these entities claim to sell their technologies exclusively to legitimate governments to fight serious crime and terrorism, investigative journalism and digital forensic analysis have demonstrated that these tools are systematically used to suppress political dissent [46].

Spyware creators have the ability to move their corporate headquarters or use complex affiliate networks to countries with extremely lax regulatory frameworks, easily bypassing geographic restrictions. The complete absence of a universal, binding international law on cybercrime allows this interstate trade to continue, turning privacy into a theoretical concept that is easily catalyzed in practice by the technological superiority of attackers. Although there have been attempts to control through the European Dual-Use Regulation for the export of sensitive tools, or through the inclusion of manufacturers such as NSO Group on the US Entity List, these legal tools have inherent weaknesses, especially with regard to intra-European technology transfers and the action of subsidiaries [47].

4.2 The need for technological (and not only legal) shielding of software

The failure of legal frameworks to curb the spread and use of spyware demonstrates that the law cannot be the only line of defence in the digital age. Legal redress or the imposition of fines after the event can neither prevent the leakage of sensitive data (PII) nor restore the compromised security of a device. For this reason, there is an urgent need for a radical shift in interest towards the technological shielding of the software itself, transforming the principles of privacy from legal imperatives into

structural, architectural components of information systems.

This approach is perfectly aligned with the philosophy of the ISO/IEC 29100 standard, which introduces the concept of privacy by design. The basic premise of technological shielding is that software must be designed with the understanding that the underlying execution environment or network is inherently hostile (zero-trust architecture). As demonstrated in the following analysis of the FORCEDENTRY attack, attackers are exploiting the blind trust that applications show in automated data flows. The technological answer to this problem is not to prohibit the use of software through laws, but to limit the attack surface through strict programming standards.

The integration of Privacy Enhancing Technologies (PETs) at the source code level is the practical means to achieve this shielding. The use of cryptographic protocols that ensure the concealment of metadata, the imposition of memory restrictions through the use of memory-safe programming languages and the isolation of critical processes at the hardware level, are the really necessary countermeasures.

In conclusion, the technological shielding of software does not come to replace law, but to offer it the necessary implementation tools. For the GDPR or any other regulatory framework to be effective, it must be supported by systems that apply the legal principles in an automated and tamper-proof manner. Only through the convergence of legal science with software engineering and international security standards, such as ISO/IEC 29100, can the gap between theory and technological reality be bridged, creating an essential shield of protection against modern cyber threats.

5. Case Study 1-Vulnerability analysis and redesign of messaging platforms (iMessage/FORCEDENTRY)

5.1 Scenario description and anatomy of the FORCEDENTRY attack

5.1.1 Background and evolution of NSO Group's zero-click attacks

The emergence of zero-click exploits represents the most significant qualitative change in the architecture of spyware. Historically, NSO Group has invested in exploiting vulnerabilities that required user interaction, primarily through targeted spear-phishing messages. However, the gradual cybersecurity education of users has forced spyware creators to develop techniques that completely bypass human behavior.

One of the first mass recordings of this transition occurred in 2019 on the WhatsApp platform. According to the National Vulnerability Database and ID CVE-2019-3568, a critical buffer overflow vulnerability has been identified in the WhatsApp VOIP stack. This vulnerability allowed RCE attacks on the target devices, sending a specially crafted data packet via call, without the victim even having to answer.

Then, in 2020, the University of Toronto's research lab "The Citizen Lab" discovered a new zero-click exploit called KISMET. Based on the findings of the workshop [46], NSO Group used KISMET to trap the personal devices of at least thirty-six journalists, correspondents and producers of the Al Jazeera news network, who were running iOS 13.5.1 or earlier. This attack was based on zero-day vulnerabilities in Apple's iMessage infrastructure, proving that the operating systems' built-in chat apps were now the main entry point for Pegasus spyware.

5.1.2 The discovery and context of the FORCEDENTRY attack

The top-of-the-line and technically most sophisticated zero-click attack was recorded in 2021 called FORCEDENTRY. The discovery of this exploit was made by Citizen Lab during an examination of the device of a Saudi activist, who suspected that he had been targeted by state actors through NSO Group's Pegasus software [48]. Tracing the device's system files revealed evidence that was absolutely characteristic of the company's methodology, according to the laboratory, confirming the trapping.

These elements included the characteristic structure and format of the malicious sent files, as well as an incomplete cleanup of an internal table of the DataUsage.sqlite file. The attackers had attempted to erase traces of the infection from the system logs, however the process failed to clear the corresponding ZLIVEUSAGE table records which reference the deleted ZPROCESS table data. These digital fingerprints have now been associated with NSO's action.

This violation had been in force since at least February 2021. On September 7, 2021, Citizen Lab handed over all digital items to Apple, which on September 13 confirmed the existence of the exploit and issued an urgent security update for the consumer public. The seriousness of the incident led Apple to the decision to file a formal lawsuit against NSO Group in November 2021, seeking the company's permanent judicial exclusion from its ecosystem and services [49].

5.1.3 Technical analysis and anatomy of CVE-2021-30860

The vulnerability received the official identifier CVE-2021-30860 from the NIST organization and was classified as an extremely high-criticality integer overflow vulnerability [50]. The weakness was found in the iOS image rendering library, specifically in the attachment file management path, which is defined as Library/SMS/Attachments. When a user receives an image file through the iMessage service, the operating system automatically triggers a background process named IMTranscoderAgent. This process is responsible for automatically previewing and managing the file before the user interacts with the screen or opens the message.

The attackers exploited this automated workflow by implementing a number of highly sophisticated techniques. Initially, they manipulated the file type, sending a total of 27 .gif files to the target device. Examination of the magic bytes of the files showed that four of them were not images, but PDF files containing encoded data streams according to the old JBIG2 compression standard. iOS's built-in JBIG2 decoder, which was used to process the scanned text within the PDF, contained a structural inability to control the limits of variables. When processing specially crafted malicious commands,

integer overflow was triggered, which allowed attackers to gain access to arbitrary memory addresses and cause heap corruption.

With an impressive sample of reverse engineering, Pegasus designers used the basic logic instructions of the JBIG2 decoder to implement logic gateways, such as AND, OR, and XOR, within memory itself. In this way, they managed to set up a standalone computer inside the memory space of the iOS library, executing the malicious code without having to call the official functions of the operating system. In particular, this exploit chain simulated a 16-bit Arithmetic Logic Unit (ALU), essentially creating a complete Virtual Machine inside the image parser. This allowed the complete bypassing of Apple's BlastDoor isolation mechanism and code execution (RCE) directly on the IMTranscoderAgent daemon [51].

5.2 Failure analysis of traditional security mechanisms

The success of FORCEDENTRY demonstrated that classical defense mechanisms exhibit structural gaps when faced with advanced persistent threats. As for iOS, it is based on the philosophy of Sandboxing where each application runs in an isolated environment, which does not allow it to access the files of other applications or the system kernel. In the case of iMessage, Apple had introduced a specialized sandbox called BlastDoor precisely to analyze untrusted data in an isolated environment.

The FORCEDENTRY attack managed to bypass BlastDoor because the vulnerability was in the code of a core system library, CoreGraphics, which had elevated privileges. With the success of the attack, now having the rights to the IMTranscoderAgent process itself, attackers gained unhindered access to the device's file system, messages, calls, and metadata, bypassing the sandbox walls.

At the same time, the attack neutralized the code signing mechanism. This mechanism enforces the strict rule that no code can be executed in the central processing unit unless it is digitally signed with a valid Apple certificate. FORCEDENTRY did not try to import or run a new, external executable, but took

advantage of the commands that were already loaded into the RAM. These already existing commands were trusted for the system since they had been loaded with the legitimate and signed JBIG2 decoder. Since the CPU was executing commands that belonged to already approved Apple code, the Code Signing mechanism did not detect any security policy violations.

With the same methodology, the ASLR mechanism was neutralized, which randomizes the memory locations where critical elements of the system are loaded to prevent an attacker from predicting their location. Due to the nature of the JBIG2 script, the attackers performed a technique known as heap spraying, read the relevant addresses, and calculated the shifts in real time, bypassing randomization protection.

5.3 Structural security upgrades in iOS 15 and their correlation with ISO/IEC 29100 and PETs

Addressing critical zero-click threats, such as the FORCEDENTRY attack, has forced the software industry to shift from simply reactive patching to a more radical and structural redesign of its systems. With the release of iOS 15, Apple introduced a number of new security protections, which included significant upgrades to the BlastDoor mechanism (Apple, 2021). According to the company's official position, while NSO Group's spyware continues to evolve, no evidence of successful remote attacks on devices running iOS 15 and later was observed, which highlights the necessity of shielding the software at the level of fundamental architecture [49].

Apple's specific technical interventions are not just isolated security measures, but are inextricably linked to the international standard ISO/IEC 29100 and Privacy Enhancing Technologies (PETs). The radical restructuring of iMessage for the processing of untrusted data implements in practice the Information Security Principle of ISO/IEC 29100. The standard stipulates that personal data protection (PII) is directly dependent on controlling and limiting process privileges. With the enhancement of BlastDoor in iOS 15, Apple imposed stricter restrictions on the sandbox, ensuring that even if a parser undergoes integer overflow, the process lacks any access to wider

system files or user identification data, thus implementing a zero-trust model at the code level.

At the same time, these changes incorporate the core philosophy of Privacy Enhancing Technologies (PETs), focusing on memory isolation and programmatic security. The need to protect against Data-Oriented Programming techniques, which were used in FORCEDENTRY to bypass Code Signing, led to the use of hardware-level Trusted Execution Environments, such as the Secure Enclave, to control sensitive operations. In addition, the gradual replacement of legacy parser libraries, written in languages such as C++, with modern memory-safe languages, such as Swift and Rust, completely eliminates the possibility of buffering or integer overflows during compilation.

Therefore, Apple's architectural shift in iOS 15 proves that effective defense against commercial spyware requires the organic integration of privacy by design, making technology standards and cryptographic PETs the only viable safety net for securing communications.

6. Case Study 2-Electronic Health Record (EHR) Development

6.1 Design of a health information system against advanced threats (zero-click spyware)

The development and management of an Electronic Health Record (EHR) is one of the biggest challenges of modern software engineering, as it requires the management of highly sensitive personal data (PII). Following the retrospective technical analysis of Chapter 5, which demonstrated how a live incident (FORCEDENTRY) can completely neutralize the security of a device at the operating system level, this Case Study shifts the focus to proactive architectural shielding. Given (Zero Trust) that medical staff's terminal devices are exposed to invisible zero-click (Pegasus) or 1-click (Predator) threats, designing a health information system requires a new approach. Instead of traditional perimeter security and massive ransomware-type attacks that simply lock down infrastructure, modern spyware enforces the integration of privacy into the very flow of code and data to prevent silent PII mining.

A realistic scenario involves the use of zero-click spyware (such as Pegasus or Predator) against key people inside the hospital, such as a doctor or a system administrator. The infection of the target's personal or corporate device can be implemented with two different attack vectors: either through invisible zero-click attacks (such as Pegasus), which exploits unknown vulnerabilities in messaging applications (e.g. iMessage) without any user interaction, or through sophisticated spear-phishing (1-click attacks, such as Predator), where the doctor is tricked into clicking on a seemingly legitimate link via SMS or Viber. When the doctor logs into the hospital's information system, the spyware intercepts their access credentials. The result is the silent and constant mining of medical data of targeted patients, completely bypassing the hospital's expensive perimeter security systems (firewalls), which consider traffic as "legal".

To holistically address this asymmetric threat, the architectural design of the health system cannot be based solely on the security of infrastructure, but must organically integrate the protection of the privacy of the subjects. This is achieved by establishing a Privacy Information Management System (PIMS) [52].

According to the international standard ISO/IEC 27701, such a system acts as a natural extension of traditional information security management systems, providing

the requirements and guidelines for both cybersecurity and data privacy protection [53]. Based on this framework, the eHealth system is designed with the assumption of Zero Trust. The design assumes that the end-user's (doctor's) device may already be silently infected with spyware. Therefore, the burden of protection shifts from the perimeter to the data itself, imposing privacy controls at the application layer and database level to prevent the escalation of the attack and the massive leakage of the electronic health record.

6.2 Modeling of roles, access rights (RBAC) and purpose limitation based on ISO 29100

The cornerstone in preventing mass data interception from an infected terminal is the rigorous implementation of the Role-Based Access Control (RBAC) model. To draw a realistic and technologically mature example, this study examines the institutional and technical framework of Hong Kong, which is one of the most advanced digital hubs in the world. In the context of this national health infrastructure, the collection, sharing, use and preservation of electronic health records (EHRs) is strictly and exclusively limited to specific, institutionalised purposes related to the provision of healthcare [54]. This approach implements the principle of least privileges, as the legislation requires the creation of an integrated information infrastructure, which allows health providers (doctors and healthcare professionals) to have controlled access to information only with the explicit consent of the patient [55].

To effectively defend against sophisticated espionage threats, whether it's zero-interaction (Pegasus) or social engineering (Predator) attacks, the EHR's infrastructure does not treat users as a single mass. Instead, it imposes access restrictions based on the "need-to-know basis" and the six fundamental Data Protection Principles (DPPs) that govern the management of PII [56]. In practice, an attending physician is authorized to access only the clinical history of the specific patients under his care, while administrative staff is limited to identification or billing data.

If spyware infects a user's device, the attacker is trapped within the strict confines of that role and is unable to laterally move the database. In perfect harmony with the data minimization and purpose limitation principles of ISO 29100, this

architecture prevents the interception of PII at large, ensuring that a breach of a terminal does not lead to a collapse of the privacy of the entire hospital organization.

6.3 Integration of privacy-enhancing technologies (PETs) and data de-identification

Even with the strict implementation of access control (RBAC), a sophisticated spyware cyberattack may compromise a system administrator's credentials, bypassing the limitations of simple roles. To prevent patients from being directly associated in the event of mass interception of the electronic health record (EHR) database, the last line of defense is to integrate Privacy-Enhancing Technologies (PETs) into the code architecture layer.

The ISO/IEC 27701 framework requires organizations to set clear data minimisation targets and to document the technical mechanisms they use to achieve this goal, such as de-identification [57]. In practice, when designing the information system, software engineers must apply pseudonymization techniques. In this architecture, direct patient identifiers (such as full name or government ID numbers) are separated from medical data (diagnoses, clinical notes, treatments) and replaced by a random token. In this way, it is ensured that the processing mechanisms and techniques fully achieve the goals of minimizing personally identifiable information (PII) [58].

In the event that spyware manages to extract the table with the clinical data, it becomes practically useless for the attacker, as it is meaningless without the separate, strictly protected and encrypted table that associates the aliases with the real persons. In addition, for data intended for secondary use, such as statistical analysis or medical research, the system must fully anonymize them. As defined by the ISO 27701 standard, the data must be converted into a form that does not allow in any way the identification or re-identification of the subjects [59]. This approach nullifies the commercial or espionage value of intercepted files, effectively protecting patient privacy.

7. Conclusions

7.1 Challenges in the Practical Application of Privacy Standards vs. Commercial Spyware

The practical integration of international privacy standards (ISO/IEC 29100 and ISO/IEC 27701) into the software development lifecycle (SDLC) faces complex challenges, stemming directly from the radical change in the threat landscape. As documented in Chapters 1 and 2, the shift from simple commercial surveillance adware to sophisticated, state-sponsored mercenary spyware, such as Pegasus and Predator, has turned the tide of traditional security. The biggest challenge lies in the technical asymmetry: defense is called upon to apply static privacy controls against dynamic exploit chains that act invisibly.

Analysis of infection mechanisms showed that zero-click attacks and advanced anti-forensics techniques (such as running exclusively on RAM-memory-only and self-destructing mechanisms) nullify the effectiveness of back-checks and traditional logs. When a platform, such as iMessage in the FORCEDENTRY attack (Chapter 5), is compromised at its core due to inherent memory management weaknesses, the application of ISO 29100 principles becomes extremely difficult. Software engineers are faced with the paradox of having to guarantee privacy in an execution environment (OS kernel) that is already considered infected and hostile, which necessitates the shift of controls from the device layer to the level of the application itself's architecture, as implemented in the EHR information system (chapter 6).

7.2 Recap and Future Directions in Software Engineering

To sum up, this research has shown that simple legal compliance (e.g. GDPR) or passive reactive patching are insufficient to intercept sophisticated threats. The industry is being forced into a radical paradigm shift. The live failure of classic defenses, as analyzed in iMessage (chapter 5), is the strongest technological incentive

for the adoption of the organic principles of "Privacy by Design", which were applied to the architecture of the electronic health record (chapter 6).

In terms of future directions, software engineering needs to incorporate privacy requirements as primary control objectives from the early stages of requirements engineering. The industry trend is now turning towards:

- The systematic use of programming languages with inherent memory-safe languages. The gradual replacement of traditional languages by modern environments, such as Rust and Swift, is considered imperative at the core of critical libraries. This approach allows for the elimination of integer and buffer overflow or heap corruption vulnerabilities during the compile-time phase, preventing the creation of arbitrary execution virtual machines (ALU emulations) within the system parsers.
- The utilization of Trusted Execution Environments (TEEs). Moving critical data processing processes to hardware-level isolation ensures that even if the operating system is completely compromised, cryptographic keys and sensitive PII remain protected within secure enclaves.
- The integration of advanced cryptographic PETs and microservices architecture. The complete architectural separation of the identification tables from the actual content data (e.g. clinical information), combined with homomorphic encryption techniques, allows statistical or operational calculations to be performed on encrypted files, eliminating the value of the information in the event of mass interception of the database.
- Addressing the "AI Paradox" and the challenges of "Vibe Coding". The integration of AI models into software engineering creates a dual asymmetry. While these tools enhance defensive capabilities, they also equip attackers with automated mechanisms for producing polymorphic spyware, which constantly alters its structure to avoid detection [60]. At the same time, the emergence of "Vibe Coding" – where software development relies on code generation through natural language and prompts – breaks down the technical barrier of entry [60]. This allows attackers with limited knowledge to compose complex and targeted chains of exploitation, rendering traditional signature-based detection methods

completely obsolete and forcing a shift to dynamic, behavioral countermeasures [60].

In conclusion, in the face of the asymmetric threat of spyware, it is not enough for software to simply function properly; It must be designed with the assumption that a device or operating system breach is inevitable, ensuring architecturally and mathematically that sensitive organization and user data will remain non-negotiably protected.

8. Bibliography

Pegasus-Product Description (NSO)

- [12]: «We provides, as default, one year of maintenance, support and upgrades services. These services include: Maintenance and Support: We provides maintenance services and three-tier level support that includes: ■Tier-1: Standard system operations problems ■Tier-2: Proactive resolving of technical problems Remote assistance using remote desktop software and a Virtual Private Network (VPN) where requested. ■Tier-3: Bug fixing and system updates of substantial system malfunctions. Upgrades: We have releases major upgrades to the Pegasus system few times a year. Such upgrades usually include: New features, New devices/operating system support, Bugs fix.", p. 40.

Spyware (Nikolaos L. Tsironis)

- [5]: "The most critical finding of this period, being at the same time the bridge between the present and the future, was the discovery of the Ghostnet network. This is one of the first large-scale cyberespionage operations, which operated undetected in 103 countries and targeted persons of high political importance... marking the transition from financial crime to digital surveillance", p. 18.
- [60]: "AI Paradox refers to the phenomenon that tools used to combat attacks and detect patterns are at the same time the strongest ally of attackers... the use of Polymorphic Spyware by attackers makes it difficult to detect the malicious code... The trend of developing software through prompts presents two main threats. Initially, the barrier of entry for the creation of malware is broken... In addition, traditional signature-based detection is weakened," p. 39-40.

Spyware Technologies: Technical Analysis, Detection and Countermeasures (Pappas Nikolaos)

- [3]: «More complex types, like Pegasus or Predator, are sophisticated tools sometimes called state grade spyware-these programs get around encrypted messaging applications; they also use zero day flaws.", p. 15.
- [4]: «A device does not show any signs when these programs operate... The program accesses the microphone, camera, or screen. It also tracks the person's location.", p. 15.
- [9]: «Avanced spyware software also use exploit chains - these chains consist of a series of software flaws linked together to obtain total access to a device. They often target mobile operating systems like iOS or Android, so attackers can get around common security measures such as sandboxing or code signing.", p. 18.
- [10]: «Zero-click attacks are hard to find and stop mainly because they leave little to no evidence. Forensic checks often uses indirect signs. These signs include odd system actions, strange data transfer and system anomalies.", p. 19.
- [14]: «Encryption and Obfuscation: Spyware encrypts its communication plus hides its operations... Self-destruct mechanisms: Some spyware deletes itself or its logs if specific events occur, for example, if the SIM card changes or someone finds it... If Pegasus detects threat analysis tools or signs of forensic inspection, it can automatically: Erase itself, Delete related logs, Overwrite memory with null bytes [2]", pp. 26 and 30.

- [15]: «Sophisticated spyware, such as Pegasus and Predator are designed to operate invisibly. On that account, common antivirus software often does not find it. Finding this software requires forensic methods and special tools... Amnesty International developed Mobile Verification Toolkit (MVT). It is an open-source software that helps identify devices that are infected with Pegasus spyware. It works by: Analyzing encrypted iPhone backups, Search for known forensic traces such as suspicious domain/IP contact", p. 25.
- [16]: «Forensic analysts examine: System logs... Network logs... Application behavior, such as unexpected battery drain or camera activation. Packet Capture and Traffic Analysis: Applications like Wireshark or tcpdump are used to monitor device traffic.", pp. 25-26.
- [47]: «In addition, the Dual-Use Regulation manages the export of sensitive tools, such as spyware, by requiring licenses... Outside the EU, the United States put NSO Group and other spyware sellers on its Entity List.", p. 54.
- [51]: «These segments implemented virtual logic gates to simulate a 16-bit arithmetic logic unit (ALU). To put it simply, it created a Virtual Machine inside the image parser", p. 28.

Click, Load, Kill: A Look into the Cyberweapon Industry in the WANA Region (SMEX)

- [18]: «When did you first notice things were wrong? What did you notice? What did you do at that point? ... Did you take any precautions online before this attack?", p. 108.

Privacy framework ISO 29100:2011/2024 (Stefanos Gritzalis)

- [7]: "Privacy framework ISO 29100:2011/2024", p. 1.
- [22]: "PII" (left column) and "Information Asset" (right column), p. 126.
- [24]: "Privacy control" (left column) and "Control" (right column), p. 126.

- [25]: "Privacy breach" (left column) and "Information Security incident" (right column). Also, below it says "Privacy risk" (left column) and "Risk" (right column), p. 126.
- [26]: "Privacy safeguarding requirements" (left column) and "Control objectives" (right column), p. 126.
- [27]: "Privacy risk management" (left column) and "Risk management" (right column), p. 126.
- [28]: "PII personally identifiable information", p. 11.
- [30]: "Data subject (PII principal)", "Natural person to whom identifiers relate", p. 12.
- [33]: "Privacy Stakeholder", "A natural or legal person, public authority, organisation or other body that may influence, be affected or considers to be affected by a decision or activity related to a PIO identifier", p. 11.
- [34]: "PII controller" "A privacy stakeholder who specifies the purpose and means for the processing of PII identifiers, other than natural persons who use data for a personal purpose", p. 12.
- [37]: «5. The principles of privacy", p. 90.

ISO/IEC 29100 (2024)

- [23]: "natural person to whom the personally identifiable information (PII) (3.7) relates", p. 2.
- [29]: "information that (a) can be used to establish a link between the information and the natural person to whom such information relates, or (b) is or might be directly or indirectly linked to a natural person", p. 2.
- [31]: "To determine whether a PII principal is identifiable, account should be taken of all the means which can reasonably be used by the privacy stakeholder holding the data, or by any other party, to establish the link between the set of PII and the natural person.", p. 2.
- [32]: "The increasing commercial use and value of PII, the sharing of PII across jurisdictions, and the growing complexity of ICT systems, can make it difficult for an organization to ensure privacy and to achieve compliance with the various applicable laws.", p. v.

- [21]: «This document provides a high-level framework for the protection of personally identifiable information (PII) within information and communication technology (ICT) systems. It is general in nature and places organizational, technical, and procedural aspects in an overall privacy framework.", p. v.
- [35]: "privacy stakeholder that processes personally identifiable information (PII) (3.7) on behalf of and in accordance with the instructions of a PII controller (3.8)", p. 2.
- [36]: "privacy stakeholder (3.20) other than the personally identifiable information (PII) principal (3.9), the PII controller (3.8) and the PII processor (3.10), and the natural persons who are authorized to process the data under the direct authority of the PII controller or the PII processor", p. 4.
- [38]: "6.2 Consent and choice" "6.3 Purpose legitimacy and specification" "Adhering to the purpose legitimacy and specification principle involves: ensuring that the purpose(s) complies with applicable law and relies on a permissible legal basis;", p. 14-15.
- [39]: «6.4 Collection limitation: limiting the collection of PII to that which is within the bounds of applicable law and strictly necessary for the specified purpose(s). [...] 6.5 Data minimization: minimize the PII which is processed and the number of privacy stakeholders and people to whom PII is disclosed or who are allowed to process it;", p. 15.
- [40]: "6.6 Use, retention and disclosure limitation", "6.7 Accuracy and quality", "6.8 Openness, transparency and notice", p. 16.
- [41]: "6.9 Individual participation and access", "6.10 Accountability", "6.11 Information security", "6.12 Privacy compliance", p. 17-19.
- [42]: "6.5 Data minimization" "minimize the PII which is processed and the number of privacy stakeholders and people to whom PII is disclosed or who are allowed to process it;", p. 15.
- [43]: "The privacy framework is intended to help organizations define their privacy safeguarding requirements related to PII within an ICT environment", "Use of this document will: aid in the design, implementation, operation, and maintenance of ICT systems that handle and protect PII;", p. v.

- [52]: "This document specifies requirements for establishing, implementing, maintaining and continuously improving a privacy information management system (PIMS).", p. 1.
- [53]: "This document enables an organization to align or integrate its privacy information management system (PIMS) with the requirements of other management system standards, and in particular with the information security management system specified in ISO/IEC 27001.", p. vi.
- [57]: "The organization should define and document data minimization objectives and what mechanisms (such as de-identification) are used to meet those objectives.", p. 30.
- [58]: "In these cases, the organization should define and document the extent to which the PII should be associated with the PII principal, as well as the mechanisms and techniques designed to process PII, such that the de-identification and PII minimization objectives are achieved.", p. 30.
- [59]: "The organization should either delete PII or render it in a form which does not permit identification or re-identification of PII principals, as soon as the original PII is no longer necessary for the identified purpose(s).", p. 31.

Supplementary material

- [1] European Parliament (2023) The impact of Pegasus on fundamental rights and democratic processes. Brussels: European Parliament. Available at: [https://www.europarl.europa.eu/RegData/etudes/STUD/2022/740514/IPOL_STU\(2022\)740514_EN.pdf](https://www.europarl.europa.eu/RegData/etudes/STUD/2022/740514/IPOL_STU(2022)740514_EN.pdf)
- [2] European Parliament Research Service (2023) Investigation of the use of Pegasus and equivalent surveillance spyware. Brussels: European Parliament. Available at: [https://www.europarl.europa.eu/RegData/etudes/ATAG/2023/747923/EPRS_AT A\(2023\)747923_EN.pdf](https://www.europarl.europa.eu/RegData/etudes/ATAG/2023/747923/EPRS_AT A(2023)747923_EN.pdf)

- [6] European Parliament Think Tank (2024) What action has Parliament taken against spyware abuse? Available at: [What action has Parliament taken against spyware abuse? | Epthinktank](#)
- [19] European Data Protection Board (2020) Guidelines 4/2019 on Article 25 Data Protection by Design and by Default. Available at: [Guidelines 4/2019 on Article 25 Data Protection by Design and by Default](#)
- [20] European Commission (n.d.) What does data protection by design and by default mean? Available at: [What does data protection ‘by design’ and ‘by default’ mean? - European Commission](#)
- [8] ENISA (2024) ENISA Threat Landscape 2024. Available at: [ENISA Threat Landscape 2024](#)
- [11] Citizen Lab. Hide and Seek: Tracking NSO Group's Pegasus Spyware to Operations in 45 Countries. Available at: [HIDE AND SEEK: Tracking NSO Group’s Pegasus Spyware to Operations in 45 Countries - The Citizen Lab](#)
- [13] Kaspersky. What commercial spyware is, and what different types there are. Kaspersky official blog. Available at: [What commercial spyware is, and what different types there are | Kaspersky official blog](#)
- [17] Cyber Forensic Academy. Best Network Forensic Tools for Packet & Log Analysis. Available at: https://www-cyberforensicacademy-com.translate.goog/blog/best-network-forensic-tools-for-packet-log-analysis?_x_tr_sl=en&_x_tr_tl=el&_x_tr_hl=el&_x_tr_pto=sge
- [44]: Kareem, K.M., 2024. A comprehensive analysis of pegasus spyware and its implications for digital privacy and security. arXiv preprint arXiv:2404.19677.
- [45]: Anstis, S., 2024. Regulating transnational dissident cyber espionage. International & Comparative Law Quarterly, 73(1), pp.259-274.
- [46]: Marczak, B., Scott-Railton, J., Al-Jizawi, S., Anstis, S., and Deibert, R., 2020. The Great iPwn: Journalists Hacked with Suspected NSO Group iMessage Zero-Click Exploit. The Citizen Lab. Available at: <https://citizenlab.ca/research/the-great-ipwn-journalists-hacked-with-suspected-nso-group-imessage-zero-click-exploit/>
- [48]: Marczak, B., Scott-Railton, J., McKune, S., Razzak, B., and Deibert, R., 2021. FORCEDENTRY: NSO Group iMessage Zero-Click Exploit Captured in the Wild.

The Citizen Lab. Available at: <https://citizenlab.ca/research/forcedentry-nso-group-imessage-zero-click-exploit-captured-in-the-wild/>

- [49]: Apple, 2021. Apple sues NSO Group to curb the abuse of state-sponsored spyware. Apple Newsroom. Available at: <https://www.apple.com/sa/newsroom/2021/11/apple-sues-nso-group-to-curb-the-abuse-of-state-sponsored-spyware/>
- [50]: National Vulnerability Database (NVD), 2021. CVE-2021-30860 Detail. NIST. Available at: <https://nvd.nist.gov/vuln/detail/CVE-2021-30860>
- Personal Data (Privacy) Ordinance and Electronic Health System: Points to Note for Healthcare Providers and Healthcare Professionals [54-56]:
 - [54]: "The Electronic Health System Ordinance, Cap. 625 ("eHealth Ordinance") provides a legal basis for the collection, sharing, use, and safekeeping of patients' health data under the Electronic Health System ("eHealth System").", p. 2.
 - [55]: "The eHealth System is an information infrastructure for healthcare providers (including doctors and other healthcare professionals) in both the public and private sectors to, with the consent of a patient, access and share the patient's health record for healthcare-related purposes.", p. 2.
 - [56]: «Patients' health records in the eHealth System amount to personal data, which is protected under the Personal Data (Privacy) Ordinance, Cap. 486 ("PDPO"). Healthcare providers and the Commissioner for the Electronic Health Record, as data users, should act in accordance with the requirements under the eHealth Ordinance as well as the PDPO (including the Six Data Protection Principles ("DPPs"))", p. 2.
- Hong Kong Government, 2026. Electronic Health System Ordinance (Cap. 625). Consolidated version. Retrieved from <https://www.elegislation.gov.hk/hk/cap625!en>
- Admin. (2023, July 21). Enhancing Healthcare Data Security with Managed Services-EHR Role Based Access-Ellit Groups. Retrieved from

<https://ellitgroups.com/enhancing-healthcare-data-security-with-managed-services-ehr-role-based-access/>

- Henry, K. (2026, March 16). Role-Based Access Control (RBAC) in healthcare: benefits, examples, and best practices. Retrieved from <https://www.accountablehq.com/post/role-based-access-control-rbac-in-healthcare-benefits-examples-and-best-practices>
- EHealth. (n.d.). Retrieved from <https://www.ehealth.gov.hk/en/whats-ehealth/access-control.html>
- National Vulnerability Database (NVD), 2019. CVE-2019-3568 Detail. NIST. Available at: <https://nvd.nist.gov/vuln/detail/CVE-2019-3568>

